

Amass Tool - Tester Workflow Report

Amass Tool — Tester Workflow Report

Step-by-Step Execution Process for Reconnaissance Testing

Purpose

This report documents the standard step-by-step process a security tester follows when using the Amass tool for reconnaissance (asset discovery), from initial setup through to final reporting. Each step includes the situation in which it applies and the corresponding command.

Step 1: Scoping and Authorization

Situation: Before any scanning begins, the tester confirms the target domain is either owned by the client, covered by a signed authorization/scope-of-work document, or — as in this test case — a publicly designated practice target.

Action: No command yet. This is a documentation/legal step: confirm target domain(s), confirm what’s in-scope (passive only? active allowed? specific subdomains excluded?), and get written sign-off.

Example target used in this test: `scanme.nmap.org` — the official public test server provided by the Nmap project for practicing scans.

Step 2: Intelligence Gathering (Discover Root Domains)

Situation: Used at the very start of an engagement when the tester only knows the *organization name*, not all of its domains. This step finds root domains associated with the company before enumeration begins.

Command:

```
amass intel -org "Target Organization Name"
```

When to use it: Only needed if the client hasn’t already given you a specific domain list. If the domain is already known (as in this test), this step can be skipped and the tester moves straight to Step 3.

Step 3: Passive Enumeration (Safe First Pass)

Situation: This is the **first scan run on any target**, always done before active scanning. It only pulls data from public third-party sources (certificate logs, DNS databases, search engines) and never sends traffic directly to the target’s servers. It’s low-risk and doesn’t disturb the target’s systems.

Command (as used in this test):

```
amass enum -passive -timeout 30 -max-dns-queries 500 -d scanme.nmap.org -oA result
```

Flag	What it does in this situation
<code>-passive</code>	Restrict the scan to public data sources only — no direct contact with the target.
<code>-timeout 30</code>	Stop the scan automatically after 30 minutes, to keep runtime controlled.
<code>-max-dns-queries 500</code>	Cap the number of DNS lookups, to avoid overloading query limits on data sources.
<code>-d scanme.nmap.org</code>	Specifies the exact domain being tested.
<code>-oA result</code>	Save output in all available formats (text and JSON) under the filename <code>result</code> .

Result of this run: The scan completed in under a minute and found **0 subdomains**. This is expected here because the practice domain has almost no public footprint — a real corporate domain would typically return dozens or hundreds of results at this stage.

Step 4: Reviewing Passive Results

Situation: After passive enumeration finishes, the tester reviews what was found before deciding whether deeper (active) testing is authorized and worthwhile.

Command:

```
amass db -show -d scanme.nmap.org
amass db -names -d scanme.nmap.org
```

In this situation: Since 0 assets were found, there was nothing further to review — the tester would note this in the report and either conclude the passive phase or proceed to active scanning if the scope allows and more data is expected.

Step 5: Active Enumeration (Deeper Pass — Requires Authorization)

Situation: Only performed **if the scope of work explicitly authorizes active testing**. This step sends real traffic to the target — live DNS resolution, reverse DNS sweeps, and (optionally) basic service checks — which can be logged or noticed by the target’s security systems.

Command:

```
amass enum -active -d scanme.nmap.org
```

Note for this engagement: This test run used passive mode only, so this step was **not executed**. It’s included here to show what the next step would look like if the client’s scope permitted it.

Step 6: Brute-Force Subdomain Discovery (Optional, Deeper Still)

Situation: Used when passive and active scans return limited results, but the tester suspects there are more subdomains that simply aren’t in any public database — for example, internal-only naming patterns.

Command:

```
amass enum -active -brute -w wordlist.txt -d scanme.nmap.org
```

Situation-specific note: This is the most intrusive option and is typically reserved for engagements where the client has explicitly asked for maximum thoroughness.

Step 7: Visualizing Results

Situation: Once a scan returns meaningful data, the tester generates a visual map of discovered assets to make the findings easier to present to the client or to HR/management.

Command:

```
amass viz -d3 -d scanme.nmap.org
```

In this test: Not applicable, since there were no assets to visualize.

Step 8: Documenting and Reporting Results

Situation: The final step in every engagement — regardless of how many (or how few) assets were found. The tester records:

- Exact command(s) run and flags used
- Start/end time and duration
- Exit code and raw output (success/failure)
- Parsed results (subdomains, IPs, DNS records found — or confirmation that none were found)
- Any errors or unexpected behavior encountered (e.g., an expected output file not being created)

In this test case: The tester logged a fully successful run (exit code 0) that took ~58 seconds and correctly reported “no assets discovered” for the practice domain — confirming the tool and pipeline both work correctly, ready to be pointed at a real, in-scope target.

Decision Guide — Which Command Does the Tester Choose, and Why?

At several points in an engagement, the tester has to make a judgment call about which mode or command to run next. This section covers those decision points.

Situation the Tester Encounters	Decision & Reasoning	Command Used
Client gave a company name but no domains	Run intel gathering first to discover root domains before anything else can happen	<code>amass intel -org "Target Organization Name"</code>
Client already gave a specific, confirmed domain	Skip intel gathering — go straight to enumeration since the target is already known	<code>amass enum -passive -d example.com</code>
Scope of work says “passive testing only” (common for a first engagement or a cautious client)	Stay in passive mode only — never touch active/brute-force commands, regardless of how few results come back	<code>amass enum -passive -d example.com</code>
Scope explicitly authorizes active testing, and passive results seem incomplete	Escalate to active mode to get live DNS / reverse-DNS data the passive sources didn’t have	<code>amass enum -active -d example.com</code>
Large organization, passive scan returns very few results, but tester suspects hidden/internal subdomains exist	Escalate further to brute-force mode — only if the scope already allows active testing	<code>amass enum -active -brute -w wordlist.txt -d example.com</code>
Data sources (Shodan, Censys, etc.) are rate-limiting the scan or missing data	Add or update API keys in a config file so more sources can be queried	<code>amass enum -config config.yaml -d example.com</code>
Engagement has a strict time window (e.g. a 1-hour testing slot)	Add a timeout so the scan can’t run past the allotted window	<code>amass enum -passive -timeout 30 -d example.com</code>
Client’s infrastructure is sensitive to query volume (small business, strict rate limits, etc.)	Cap the number of DNS queries to stay conservative and avoid disruption	<code>amass enum -passive -max-dns-queries 500 -d example.com</code>

volume (small business, strict rate limits, etc.)	avoid disruption	example.com
Tester needs to know exactly which data source found each result (for report credibility/auditing)	Add the source-attribution flag so every finding is traceable to its origin	<code>amass enum -passive -src -d example.com</code>
Tester wants IP addresses included alongside subdomains for network mapping	Add the IP flag to enrich the output with address data	<code>amass enum -passive -ip -d example.com</code>
Recurring/retainer engagement — tester wants to see what’s newly appeared since the last scan	Use tracking instead of running a fresh enumeration from scratch	<code>amass track -d example.com</code>
Multiple domains are in scope at once (e.g. a company with several brands)	Provide a domain list file instead of running the command repeatedly by hand	<code>amass enum -passive -df domains.txt</code>
Tester needs to present findings to a non-technical audience (client, HR, management)	Generate a visual graph instead of relying on raw text output	<code>amass viz -d3 -d example.com</code>
Scan finished but the expected output file wasn’t created (as seen in this test’s log)	Re-run with verbose logging to diagnose the issue before treating results as final	<code>amass enum -passive -v -d example.com</code>

General decision principle the tester follows: Always start at the least intrusive option (passive) and only escalate to active or brute-force methods if (a) the client’s scope of work explicitly permits it, and (b) the previous, less intrusive step didn’t provide enough coverage. This “escalate only when needed and authorized” principle is the core judgment call behind every command choice above.

Summary Table — Full Tester Journey

#	Step	Situation	Command Used in This Test
1	Scoping & authorization	Before any scan	<i>(no command — approval step)</i>
2	Intel gathering	Domain unknown	<i>(skipped — domain was already known)</i>
3	Passive enumeration	First safe scan on any target	<code>amass enum -passive -timeout 30 -max-dns-queries 500 -d scanme.nmap.org -oA result</code>
4	Review results	After passive scan completes	<code>amass db -show -d scanme.nmap.org</code>
5	Active enumeration	Only if scope allows	<i>(not run — passive-only scope)</i>
6	Brute-force discovery	Need deeper coverage	<i>(not run — not required)</i>
7	Visualization	Have data to present	<i>(not run — no results to visualize)</i>
8	Reporting	Always, at the end	This report

This report reflects a passive-only reconnaissance test against a publicly designated practice domain (scanme.nmap.org), used to validate the scanning tool and workflow ahead of any real client engagement.